

SIT 218/738: Secure coding

Pass task 2.4P: Web server security

Task 1:

Complete the steps provided in “**Ontrack Task2.3P Activity**” on CloudDeakin before completing this task. Take screenshots of all your steps. Add those screenshots and details of your steps in Task submission report.

Task 2:

Explain the significance of the following HTTP security headers:

- Content-Security-Policy
- X-Content-Type-Options
- Strict-Transport-Security
- X-Frame-Options
- X-XSS-Protection (legacy)
- Referrer-Policy
- Permissions-Policy
- Access-Control-Allow-Origin (CORS settings)

Collect HTTP headers for three websites using browser developer tools.

On your windows PC/laptop

1. Go to your website of choice
2. Open the browser’s **Developer Tools (Right-click on your browser and select "Inspect" or "Inspect Element")**
3. Navigate to the **Network** tab ( **Network** with this symbol) and reload the page.
4. Click on the main request (usually the one with / path, at the top).
5. In the **Headers** section, review the **HTTP Response Headers**.

Record your findings below and add to your answer sheet:

Website	Security Header						
	Strict-Transport-Security	Content-Security-Policy	X-Frame-Options	X-Content-Type-Options	Referrer-Policy	Permissions-Policy	Access-Control-Allow-Origin

Indicate 'Yes' or 'No' for each website to show whether the specified headers are present.
Additionally, include screenshots of the headers for each website

Submission Requirements of Task:

You need to submit answer of Task 1 and Task 2 as mentioned in the above. In addition, write a short note reflecting on which secure coding principle we are applying by hardening the tomcat server in Task 1.

Submission Due

The due for each task has been stated via its OnTrack task information dashboard.